



Welcome Aboard! We're pleased to share the following answers to questions submitted through our VSA process.

Organization Questions

Q: What are your biggest security concerns driving a request for a penetration test?

A: Ensuring our existing and new systems and services are secure.

Q: What is your main reason for contracting this penetration test?

A: During the downtime of COVID, the company invested heavily in guest-focused digital upgrades, rolling out or enhancing systems. While these upgrades advanced the company's guest experience vision, routine security testing and system audits were postponed.

Q: What specific concerns or recent events prompted your interest in a penetration test?

A: Our primary security concern is ensuring that our critical systems (ranging from guest services and payment processing to operational technology aboard our vessels) remain resilient against evolving cyber threats. The cruise industry has become increasingly digital, and protecting sensitive customer and corporate data is vital to maintaining trust, safety, and operational continuity.

The main reason we are contracting this penetration test is to obtain an independent, expert assessment of our current defenses. We want to identify and remediate vulnerabilities before they can be exploited, while also meeting insurance and regulatory expectations. This testing will help us validate our recent post-COVID security improvements and confirm that they align with modern threat landscapes.

Our interest in conducting this penetration test was prompted by both external and internal factors: growing industry-wide cyberattacks against travel and hospitality providers, insurance requirements mandating regular security testing, and our own commitment to proactively strengthening security controls. A recent review of our IT environment highlighted the importance of validating controls through real-world testing, which makes this engagement a logical next step.

Q: For the final report, what would you like us to emphasize most such as Active Directory vulnerabilities, web application findings, or internal services?

A: All risks and weaknesses to systems and services should be considered for impact to business functionality and emphasized as such.

Q: During the security audit, should there be a focus on user end services such as external websites, or is there an emphasis on internal services?

A: All risks and weaknesses to systems and services should be considered for impact to business functionality and emphasized as such.

Q: What outcomes or deliverables does APT consider the most important for this assessment, including focus areas and the way findings are reported?

A: We don't want instances of people going overboard due to systems that we control (technical systems). Our ships are big but also have sensitive systems that are responsible for keeping 3,000+ people safe. Systems must be resilient if they're going to be in the middle of the ocean. We want to confirm that our role-based access control we've implemented over the past ~5 years is working.

All risks and weaknesses to systems and services should be considered for their impact to business functionality and emphasized as such. Of particular importance is validating that our role-based access controls are functioning as intended, given recent investments.

Q: What commonly recognized industry security standards or reporting formats (e.g., NIST CSF, SOC 2, ISO 27001) does APT prefer vendors align with in deliverables?

Q: How would you define a successful penetration test, including the outcomes you expect and the reporting format and level of detail (executive summary, detailed technical findings, or both) that would provide the most value to your organization?

A: We expect a penetration testing company to be able to determine how to present the information to us. We would consider the test successful if it provides both an executive summary that communicates risk in business terms, and detailed technical findings that our IT teams can act on. This combination will allow us to prioritize remediation and clearly report back to leadership and insurers.

Q: What current security policies/practices are already in place?

A: Each ship has dedicated security personnel on staff, primarily focused on physical security and passenger safety. Beyond that, we maintain a set of security policies and practices that address both our shoreside and shipboard environments. These include:

- *Access control policies for both IT systems and physical areas, including crew ID badges and role-based access to critical systems.*
- *Network security measures, such as firewalls.*
- *Endpoint security controls, including regular patch management.*
- *Incident response and escalation procedures to coordinate between shipboard personnel and the shoreside security team.*
- *Vendor and third-party risk management, particularly for satellite connectivity and onboard service providers.*
- *Crew training and awareness programs covering phishing, account security, and safe handling of guest information.*
- *Regular security audits and compliance checks, often tied to insurance and maritime regulatory requirements, including this pentest!*

Q: What type(s) of sensitive data does APT handle that [team] should be mindful of when conducting the Penetration Test?

A: As a cruise line, we handle multiple categories of sensitive data, including Personally Identifiable Information (PII), Payment Card Information (PCI), Health and Medical Data (PHI), Travel and Itinerary details, Employee and Crew Records, and Operational Technology (OT) and ship systems data, along with proprietary intellectual property of All Ports Tours.

Q: What is the classification of data that our team may run into during the testing phase? Knowing this information will help us better prepare for properly handling the data in a safe and secure manner.

A: As a cruise line, we handle several categories of sensitive data that must be safeguarded throughout the penetration test. These include Personally Identifiable Information (PII), Payment Card Information (PCI), Health and Medical Data (PHI), Travel Itinerary and Loyalty Information, Employee and Crew Records, and Operational Technology (OT) and Ship Systems Data.

We classify data into the following categories: Confidential, Internal Use Only, and Public. During the penetration test, the security team should assume that any PII, PHI, or PCI data encountered is Confidential and must be handled with strict care, following secure handling and non-disclosure practices.

Q: What is your current policy on storing personally identifiable information?

A: We need to store some PII for passenger reservations, such as the data types detailed above. We are committed to storing this data securely on our systems to protect our customers' trust in our business. We do not sell this data to third parties when prohibited by law. We are considering moving away from having a distinct data category called "PII" and instead treat all data originating from customers as "Customer Data". All customer data would be treated as 'PII'.

Q: Is the primary goal to establish a recurring engagement, such as quarterly penetration testing under a long-term contract, or is this focused on assessing a newly deployed environment to validate its initial security posture?

A: We are seeking firms to perform an initial pentest engagement in October or November 2025, with a retest to validate remediations in January, 2026.

Q: How does All Ports Tour handle privileged account access for employees and vendors, and are these accounts monitored separately?

A: Privileged account access for both employees and vendors is governed by strict access control policies. Shared administrative accounts are avoided whenever possible; instead, privileged users are assigned named accounts for accountability. Vendor and contractor accounts are provisioned only for the duration of their support activity and are disabled immediately after. Privileged accounts are logged and monitored separately from standard

user activity. Security Information and Event Management (SIEM) systems are used to flag unusual login times, locations, or activities for investigation via our third-party Managed Security Services Provider (MSSP).

Q: To ensure we operate responsibly and in full alignment with APT's customer security policies, can you clarify the process for establishing and confirming scope prior to the assessment date? Specifically, how should we request and receive approval for high-impact actions (such as privilege escalation, account creation, or persistence mechanisms) so that expectations are fully defined in advance, no ambiguity arises during testing, and the assessment can be performed safely and effectively?

A: The finalized scope will be provided during the morning briefing while you are onsite at our branch locations to perform the penetration testing engagement. Any questions about the scope or concerns about attempting a certain type of technique during the assessment should be addressed with the APT team via a support ticket.

Q: How much shore infrastructure is All Ports Tours responsible for, and what will be considered in-scope or out-of-scope regarding marine ports?

A: Please use our ticketing system for any questions or deviations regarding scope. We'll communicate the scope in writing prior to your engagement during our onsite briefing.

Q: Is All Ports Tours subject to regulations that are industry-specific to compliance standards that are relevant to state, federal, or international laws and would this would include how the company is required to handle cybersecurity, safety, or operational risks. If any of these are true, which regulations would apply and how do they influence current Cybersecurity, and IT practices?

Q: Is APT concerned with regulatory implications of any discovered security issues and if so which governance regulations, compliance standards, and security benchmarks would APT like our team to focus on during the engagement?

Q: Are there any specific legal or regulatory considerations that must be met, such as PCI DSS or GDPR?

Q: Which regulatory or industry compliance frameworks apply to your organization that you would like to be considered during our evaluation?

Q: Will our team be expected to assess security compliance as part of our engagement?

Q: Will compliance with regulatory standards be part of this penetration testing engagement?

Q: As we conduct our assessment are there any specific requirements or compliance standards that are to be adhered to, that are not already mentioned in our previous communications?

A: We are subject to International Maritime Organization (IMO) SOLAS (Safety of Life at Seas) requirements, and our handling of customer data requires consideration of standards such as PCI DSS, GDPR, and relevant health data protections. That said, we are not seeking a compliance evaluation as part of this engagement, as other partners manage those assessments for us.

Q: Is there anything else about your security measures or upcoming initiatives that you think would be helpful for us to know?

A: This is our biggest initiative for the year, we are looking forward to the results of your assessment so that we can use them to define our upcoming primary initiatives. Additionally, we are currently considering a migration from Active Directory to Entra and may consider moving our systems into hybrid mode in the future. While this will not be completed in time for your assessment, we'd appreciate any thoughts you have as you see potential in that migration.

Q: In order to provide comprehensive penetration testing services to APT, should our firm be aware of any past or present concerns with APT network or system security?

A: Our biggest concern is that it has been over five years since our last penetration test, during which time we've expanded automation, remote operations, and IT consolidation. While we believe our team is maintaining strong security practices, we want external validation to confirm our defenses remain effective against today's threats.

Q: When we conduct our network scanning and enumeration, should we operate in a stealthy mode to test your detection capabilities, or a more aggressive mode to ensure comprehensive discovery even if it's noisy?

A: Given the limited timeframe of your test, we'd encourage you to be as efficient as possible with your tools and testing; however, please remember that denial of service testing is not in scope and so we cannot have any volumetric testing done or systems brought down from testing that is too aggressive.

Q: How's your day been?

A: We ask that questions remain focused on the engagement and technical scope. Personal questions such as these are not appropriate for Vendor Assessment Questionnaires.

Environment Questions

Q: What can we expect from the environment with the in-person penetration test? Specifically, what tools are provided to move data from the penetration test environment to our secure machines to finish the report, and what tools will be provided by default?

A: Your firm will be provided with a Windows VDI instance for each member which will have access to the client environment. From this VDI instance, you will also be able to access Linux/Kali instances. We will also provide each firm with a Microsoft OneDrive account for collecting any evidence and artifacts needed for reporting purposes. (Note: You may have to use your corporate device to access our VDI Instances unless otherwise specified by your regional host.)

All work during the assessment phase of the pentest must be done entirely within the VDI environment. This includes, but is not limited to, report writing and inter-team communication (such as chat). Any evidence collected should be stored in the provided OneDrive account. After the completion of the assessment phase of the pentest, you may access the OneDrive account from your firm's machines (personal systems) to complete your report submission.

Q: Can the firm expect to be contracted to assess the security of cloud platform architecture implementations of the client, and if so, can the cloud platform in use be disclosed prior to the assessment?

Q: Could you please detail whether your environment integrates with any cloud service providers, and if so, which of these cloud assets, services, or APIs are public-facing and would be considered in-scope for enumeration and testing?

Q: Will there be a cloud environment (Azure, AWS, GCP) included as part of this penetration test this time?

A: Our business uses ships, not airplanes. At this point we have not migrated any of our workloads to the cloud as we have found that the ship-board networking can be limited, requiring more bespoke connection and hosting.

Q. Will the All Port Tours assessment require testing any volatile technologies that may pose an elevated risk to business continuity when compared with the rest of the scope?

Q: Are there any critical systems, workstations, or network segments that require special handling during testing due to operational sensitivity, compliance requirements, or potential for service disruption?

A: Our ships have a number of life-critical systems that are crucial to the health and safety of our employees and customers. Impacting these systems during a test will have significant consequences.

Q: To ensure we operate safely, are there any specific systems, data, or attack techniques (e.g., denial-of-service) that are explicitly out of scope?

A: The scope we have provided does not include any systems that have had issues in the past, but we would encourage you to use your own expertise as you get into the testing to limit any denial of service or volumetric testing.

Furthermore, we have a few systems that we would like to call out as explicitly out of scope:

- *Third-party vendor systems such as bars, restaurants, and entertainment platforms are excluded from testing.*
- *Any live testing that could disrupt passenger safety, propulsion, or navigation during voyages is strictly prohibited.*

These Networks are specifically Out-of-Scope

- **VDI**
- **VPN**
- **RIT Cyber Range**
- **Regional Host/University Environment**

These Tools are specifically Out-of-Scope

- *Our Technology Partner's Deployment Tool (LaForge)*
- *Our Managed Security Service Provider's Log Collection Agent (SplunkUniversalForwarder)*

Q: Are there any restrictions on the tools we can use in your networks?

*A: Per our rules of engagement, we do not permit the usage of tools with a commercial license. (Out of character: Review the rules language on the limitations of commercial licensing and tooling.) **Do not use tools that communicate externally without prior written approval from the APT Security Team.** We ask that you do a thorough review and understand the functionality of any tools you are bringing into our environment to minimize the impact of a wayward or malicious tool.*

Q: What are the most critical assets of the business?

Q: What are your top three primary business-critical assets and systems, and which of them would cause the most disruption if compromised?

A: Any system that would pose a risk to human life if it were operating abnormally would be considered critical to our organization

Q: What are the most important assets that APT wants to keep secure and protect?

*A: When we talk about the most important assets we must protect, it begins and ends with **human life**. The safety of our guests and crew is the cornerstone of everything we do. While ships, systems, and data are critical to operations, their value is ultimately measured by how well they safeguard the people who entrust us with their journeys at sea.*

Q: Are there any pertinent systems or software that All Ports Tours is most concerned about an adversary accessing? We want to ensure that these assets are prioritized throughout the duration of our assessment.

A: Please see above.

Q: To scope our testing effectively, could you provide a current network diagram, highlight the assets or business units you'd like us to prioritize, and share any past incidents or concerns you'd like us to focus on during our engagement?

A: Our network diagram flew away in an unfortunate porthole incident. Our head chef was working on creating a new one but ran out of napkins.

Q: What are your top business-critical systems or processes that you are most concerned about protecting, and how much tolerance do you have for potential disruptions during testing?

A: Any system that would pose a risk to human life if operating abnormally would be considered critical. We will not tolerate any loss of human life.

Q: Which kinds of operational and IT systems exist within the organization?

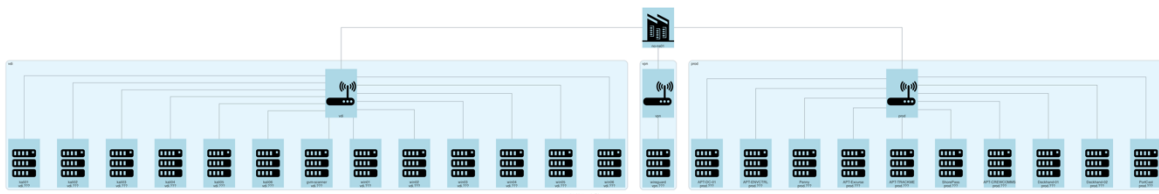
A: We operate a mix of traditional IT systems (email, identity management, and enterprise applications) alongside business-critical platforms that support our operations. These systems are secured with industry-standard controls and aligned with best practices to ensure confidentiality, integrity, and availability.

Q: Can we please get the business criticality for the services in APT Systems, for us to better align our reports.

A: All running services are critical for the business needs of APT and all due diligence should be taken to prevent the disruption of services.

Q: Will our team be provided with the topography of the network and/or a list of machines or IP addresses that are considered in-scope prior to the test?

A: Unfortunately, our head of Networking is out but we were able to dig this up.



Q: What technologies does your team use in their corporate network?

A: Our boats are our most critical assets – they are how we make money, and how we keep our passengers safe. Without them our business is unable to function. On the corporate side, we operate a mix of traditional IT systems (email, identity management, and enterprise applications) alongside business-critical platforms that support our operations.

Q: Where is customer data stored (e.g., geographic location, cloud providers)?

A: We utilize on-premise storage in the United States or on our ships in the high seas.

Q: To better prepare for this assessment, could you provide any insight into APTs previous security history? Ex. Any previous security incidents?

A: APT previously conducted annual security testing, but due to the economic downturn during COVID-19, it has now been over five years since our last penetration test. While we have not experienced any high-severity incidents beyond typical low-level spam and phishing attempts, this gap in external validation is a concern, and we are seeking your expertise to confirm the strength of our current security posture.

Q: We are excited to work with a cruise line for the first time, and this unique setting leads us to be curious about the current network topography and security precautions already on the network aboard All Ports Tours' ships.

A: Please see above.

Q: As per the VSA, we have noticed your special interest in assessing the security of containerization technologies. While we have responded to that clause, we wonder if there are any special demands or requirements for that items.

A: APT asks that testers respect that running services are actively used by employees and customers and all care is taken into mind to prevent the disruption of services. If any systems are out of scope, the testing team will be informed of such.

Q: Will the environment the assessment is being performed on be a production or non-production environment?

A: This will be our production environment. Unfortunately, due to our economic troubles we are unable to provide a realistic non-production environment.

Q: Is APT seeking security assessment of ship features that potentially require physical access, including physical security itself as well as onboard AI concierges or sommeliers, for example?

A: We do not anticipate any physical pentesting for the first phase of our assessment in October/November. We may expand the scope for the follow-up testing in January.

Q: Is there anything specific we should focus on or avoid during the assessment?

A: We are most interested in a complete, end-to-end assessment rather than narrowing in on any single system or area. The only exclusions are safety-critical ship operations (propulsion, navigation during active voyages) and explicitly out-of-scope third-party vendor systems, which we ask you to avoid.

Logistics Questions:

Q: Would there be any funding assistance for travel/lodging if needed?

A: Support for travel and lodging would be at the discretion of each regional host, but we are not aware of any regionals which are doing that this year.

Q: Are there any other action items for the vendor before the regional engagement begins? Right now we are tracking the registration form and GitHub repository creation.

A: You should have already completed tasks such as the roster and resume submission, and the completion of the vendor's Non-Disclosure Agreement (NDA). Please be aware of the deadlines for requesting the creation of a GitHub repo and timeframes for making any changes, and pay attention to your email for any requests from the client prior to the start of the assessment.

Q: Can you give us information about the point of contact, during the pentest? And whether your SOC blue team is aware if the penetration test is taking place.

Q: Will our IPs be blocked in this engagement, and should our test include detection prevention measures?

A: Your main POC at the client will be Bailey Finn, the Director of Technical Services at All Ports Tours. We assume he will inform the MSSP providing security services at APT that a pentest is taking place.

Q: Will the scenario have port-specific challenges, or is it more about general maritime operations

A: Some of our systems have ports exposed, so they should definitely be reviewed. We are not sure how challenging it will be to review them.

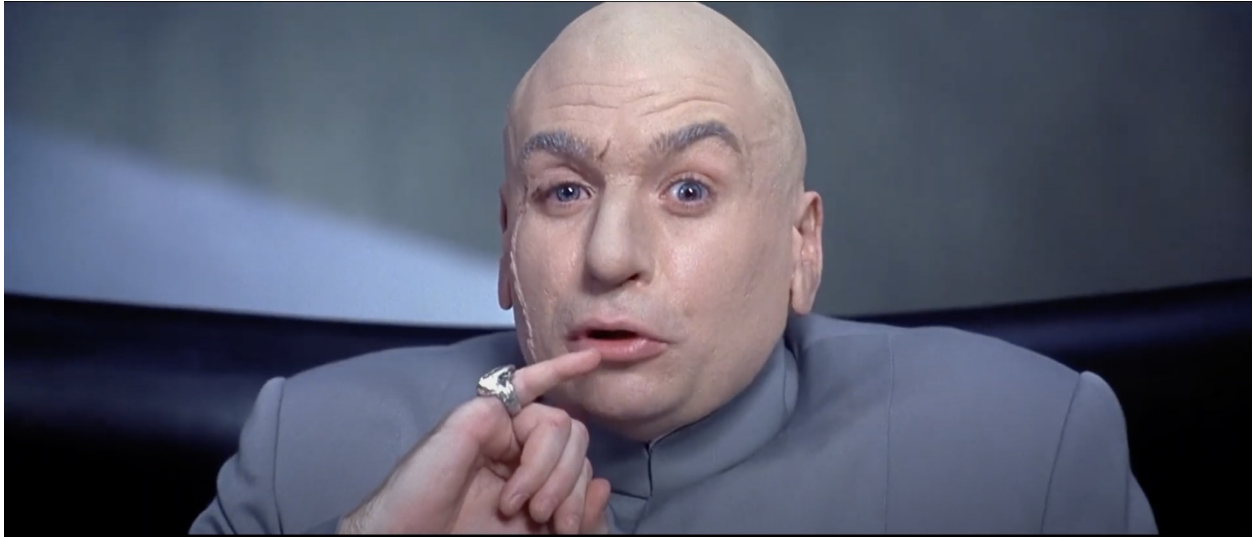
Q: We are curious if using a tool like pwndoc to generate pentest reports is allowed?

A: You can use tools such as pwndoc to assist with generating reports. However, any data that you need for evidence must be stored on the competition-provided Microsoft account,

and you will need to perform any reporting work on the competition-provided VDI (Remote Desktop) systems during competition hours (after the assessment phase in the evening, you can continue working on reports from your personal machines, but client-information should not be submitted to any other third party).

Q: What is expected budget range allocated for this assessment?

A:



Q: For what portion of the competition does our coach (professor) need to be present? He needs to be back on Monday for class, so being able to leave as early as possible on Sunday is best.

A: The coach needs to travel with your team and be present onsite during all parts of the competition and serves as the representative of your University to the competition. We will hold the awards ceremony on Sunday after the grading of deliverables.

Q: penetration testing tools or techniques do you find most effective in identifying vulnerabilities that are often missed by beginners?

A: NetExec 🤓

Rules/CPTC Policy/Resources Questions

Q: Are we allowed to access locally-hosted open-source tools during the competition? E.g. a team member starts a service locally (Ghostwriter/reporting tool, C2, etc.) that the other team members access and use.

A: Teams may run whatever tools they would like within the competition-provided VDI environments, provided they are otherwise permitted under the CPTC rules.

Please note: The VDI environment becomes unavailable at the end of the assessment phase.

Q: Are we allowed to access NON-locally hosted open-source tools during the competition? E.g. hosting an open-source tool on an external team-controlled server.

A: No. Teams may not access external resources such as an external team-controlled server during the event.

Q: Would we be able to request authorization to use a locally hosted file share during the competition?

A: Teams will be provided with a Microsoft account during the event that must be used for any file-sharing requirements. You may use a locally hosted file share within the VDI environment but you will not have access to that resource during the dedicated reporting hours.

Q: What do you recommend as good resources our organization can use to prepare for this competition?

A: We have a bunch of resources we've released (and seen) to help teams prepare. Here are a few suggestions:

- *Take a look at the CPTC YouTube channel for some examples of details from previous events,*
<https://www.youtube.com/channel/UCWMSVYHrdtFS7lxTAPHPs-w>

- Report examples from previous events (these are great to see what teams typically submit as reports, as well as provide details on types of findings that are seen and how they are presented to us): https://github.com/globalcptc/report_examples
- Take a look at blogs that have been put out from previous competitors, such as <https://www.bugcrowd.com/blog/a-look-inside-global-collegiate-pen-testing/>, <https://julian-pena.com/2024-01-19-cptc9-experience-pentesting-an-airport/>, and <https://dumosuku.com/posts/CPTC/>

Q: Your organization limits personal belongings during the test which is understandable when thinking about security. Considering this, are we able to bring printed notes? Some of us have books, or notes that we can print that we often refer to

A: In accordance with the Competition Conduct section of the CPTC rules, “Printed reference materials (books, magazines, checklists) are permitted in competition areas and teams may bring printed reference materials to the competition.” (page 3)

Q: Are we allowed to stage any binaries before the engagement to have in our GitHub? If so, are they allowed to be obfuscated of any sort?

A: You are permitted to upload binaries to the GitHub repo provided by CPTC. Any binaries that are uploaded must not be obfuscated and should include documentation/a readme as to their purpose and usage. This ensures we can understand what any tool is meant to accomplish when we review the content on the repos.

Q: For this year's CPTC, can we expect to do OSINT prior to the engagement, as last year there wasn't any?

A: We would expect any firm to do their due diligence in regard to researching the organization they are pentesting. OSINT has been a part of every CPTC season, including CPTC10.